

Phishing

Phishing คืออะไร?

Phishing คือ วิธีการที่นิยมและพบได้บ่อยที่สุด เป็นการหลอกลวงขโมยข้อมูลส่วนบุคคลของเป้าหมายจากการสร้างสถานการณ์ เช่น การส่งข้อความ SMS , Email หรือ การ Fake website ที่ทำให้ดูมีความน่าเชื่อถือเพื่อหลอกล่อให้เป้าหมายเชื่อ แล้วทำการกรอกข้อมูลส่วนบุคคล เช่น เลขบัตรประชาชน รหัสผ่าน OTP หรือ เลขที่ Passport รวมถึงให้ทำธุรกรรมต่างๆตามที่ผู้โจมตีต้องการเพื่อขโมยข้อมูลของเป้าหมายมาใช้ประโยชน์ โดยที่ข้อมูลนั้นไม่ได้รับอนุญาตจากเจ้าของข้อมูล โดยคำว่า Phishing มาจากคำว่า Fishing ที่แปลว่า ตกปลา



ประเภทของการโจมตี Phishing ที่พบบ่อย มีดังนี้

1.1 Email Phishing

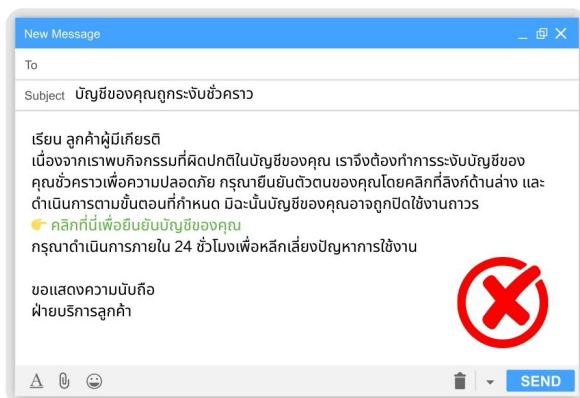
Email Phishing คือการส่งข้อความหลอกลวงผ่านทางอีเมล เป็นการโจมตีรูปแบบหนึ่งที่นิยมและพบบ่อยมาตั้งแต่ยุคแรกๆ โดยผู้โจมตีจะ ส่งอีเมลหลอกลวงโดยอ้างว่ามาจากแหล่งที่น่าเชื่อถือ เพื่อหลอกล่อให้บุคคลเปิดเผยข้อมูลที่ละเอียดอ่อนหรือดำเนินการบางอย่าง โดยอาจจะใช้ความสัมพันธ์ของบุคคล สถาบันการเงิน หรือองค์กรที่สังกัด เพื่อให้ดูน่าเชื่อถือ ซึ่งเนื้อหาใน Email นั้น อาจบอกถึงความจำเป็นเร่งด่วน ที่จะต้องกรอกข้อมูล หรือแจ้งการให้ข้อมูลส่วนบุคคล เช่น Username หรือ กรอกข้อมูลบัญชีหรือรหัสผ่าน

ลักษณะสำคัญของ Email Phishing

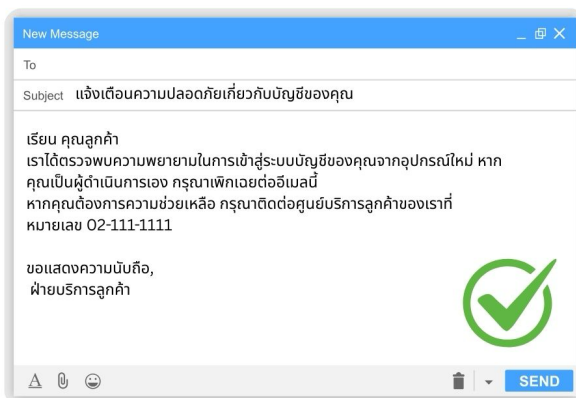
1. **ตรวจสอบที่อยู่อีเมลของผู้ส่ง** อีเมลที่มาจากแหล่งที่น่าเชื่อถือหรือโดเมนที่ผิดปกติ เช่น banka.sec123@gmail.com อาจจะเป็นสัญญาณของ Phishing
2. **ตรวจสอบลิงก์** อย่าคลิกลิงก์ในอีเมลที่คุณไม่แน่ใจ ลองเอาเมาส์ไปชี้บนลิงก์เพื่อดู URL ที่แท้จริงว่ามาจากแหล่งที่น่าเชื่อถือหรือไม่
3. **เนื้อหาที่มีข้อผิดพลาด** การสะกดคำผิด, รูปภาพผิดปกติ หรือข้อความที่เขียนดูผิดพลาดอาจเป็นสัญญาณว่าอีเมลนั้นเป็น Phishing
4. **การขอข้อมูลที่ไม่สมเหตุสมผล** ธนาคารหรือองค์กรที่เชื่อถือไม่ได้ขอข้อมูลส่วนตัวผ่านทางอีเมลโดยตรง หากได้รับคำขอที่ไม่ปกติ เช่น รหัสผ่านหรือลงทะเบียนข้อมูลทางการเงิน ต้องระวัง
5. **อีเมลที่มีอารมณ์เร่งรีบรวดรัด** ข้อความที่มักมีลักษณะเร่งด่วนหรือใช้คำที่ทำให้เกิดความเครียด เช่น "บัญชีของคุณถูกล็อค" หรือ "คุณต้องกรอกข้อมูลทันที" ถือเป็นสัญญาณที่ต้องระมัดระวัง

ตัวอย่าง Email

จาก: support@bank-secure.com



จาก: security@krungthai.com



ความแตกต่างระหว่าง อีเมลจริง และ อีเมล Phishing ในตัวอย่างมีดังนี้

1. ที่อยู่อีเมลของผู้ส่ง

อีเมลจริง: ใช้โดเมนขององค์กรที่เป็นทางการ

อีเมลปลอม: ใช้โดเมนแปลก ๆ หรือคล้ายของจริง

2. ภาษาที่ใช้

อีเมลจริง: ใช้ภาษาทางการ ไม่มีคำผิด และไวยากรณ์ถูกต้อง

อีเมลปลอม: มักมีคำผิด ไวยากรณ์แปลก ๆ หรือใช้คำแรงเร้าให้ตื่นตระหนก

3. ลิงก์ที่แนบมา

อีเมลจริง: ลิงก์ไปยังเว็บไซต์ที่เป็นทางการ

อีเมลปลอม: ลิงก์ไปยังเว็บไซต์ปลอม

4. ความเร่งด่วนของข้อความ

อีเมลจริง: แจ้งข้อมูลปกติ ไม่มีการข่มขู่ให้รีบดำเนินการ

อีเมลปลอม: ใช้ข้อความเร่งด่วน เช่น "บัญชีของคุณถูกล็อก!" หรือ "กรุณายืนยันภายใน 24 ชม. มิฉะนั้นบัญชีจะถูกระงับ"

5. การลงชื่อ

อีเมลจริง: มีชื่อบริษัท ข้อมูลติดต่อชัดเจน เช่น เบอร์โทรและเว็บไซต์

อีเมลปลอม: ไม่มีข้อมูลติดต่อ หรือใช้ข้อมูลปลอม

วิธีรับมือกับอีเมล Phishing

1. **ไม่คลิกลิงก์ในอีเมลที่น่าสงสัย** หากได้รับอีเมลที่ดูน่าสงสัย อย่าคลิกลิงก์หรือดาวน์โหลดไฟล์จากอีเมลนั้น ควรเข้าเว็บไซต์ที่แท้จริงโดยตรง โดยลิงก์ดังกล่าวอาจเชื่อมโยงไปยังเว็บไซต์ปลอมและถึงแม้ว่าจะขึ้นต้นด้วย <https://> ก็ควรตรวจสอบก่อน ในส่วนของเอกสารหรือไฟล์แนบ ซึ่งวิธีสังเกตคือให้ลองเอาเมาส์ไปวางที่ลิงก์นั้นโดยไม่ต้องกด จะเห็นข้อความขึ้นเป็นเส้นทางลิงก์ปลายทาง จะพบว่าลิงก์ปลายทาง ไม่ใช่เว็บไซต์ทางการ แต่เป็นเว็บอื่น
2. **ตรวจสอบกับองค์กรที่อ้างถึงในอีเมล** หากอีเมลอ้างว่าเป็นจากธนาคารหรือองค์กรใด ๆ ให้โทรติดต่อหรือเข้าเว็บไซต์ขององค์กรนั้นโดยตรงเพื่อสอบถาม
3. **ใช้ซอฟต์แวร์ป้องกันไวรัสและสแกนระบบ** ให้ใช้ซอฟต์แวร์ที่สามารถตรวจจับอีเมล Phishing และมัลแวร์ได้
4. **เปิดใช้งานการยืนยันตัวตนสองชั้น (2FA)** วิธีนี้จะเพิ่มความปลอดภัยในการเข้าใช้บัญชีออนไลน์ และทำให้ยากขึ้นสำหรับผู้โจมตีในการเข้าถึงบัญชีของคุณ
5. **รายงานอีเมลที่สงสัย** หากได้รับอีเมล Phishing ควรรายงานให้บริษัทหรือองค์กรที่เกี่ยวข้องทราบ เพื่อช่วยป้องกันไม่ให้ผู้อื่นตกเป็นเหยื่อ

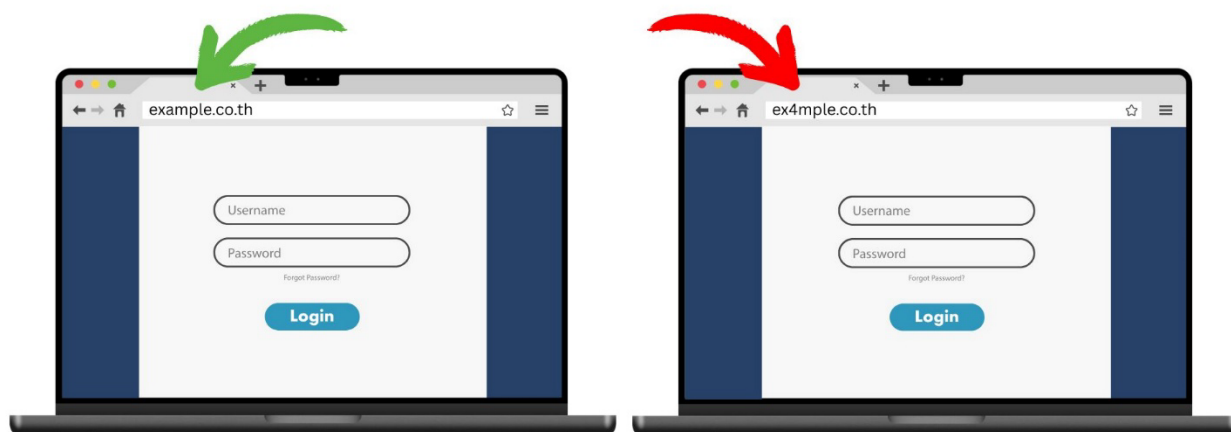
1.2 Web Phishing

Web Phishing หรือการหลอกล่อให้ผู้ใช้งานคลิกเข้าไปในเว็บไซต์ที่เป็นสแปม โดยผู้โจมตี จะสร้างเว็บไซต์ขึ้นมาหน้าหนึ่ง แล้วปรับแต่งให้ดูคล้าย ๆ กับเว็บไซต์ขององค์กรที่มีอยู่จริงเพื่อติดตามเหยื่อ วิธีสังเกตคือ URL จะมีส่วนที่ ต่างกันนิดหน่อย เช่น จาก example.co.th ก็ปลอมแปลงเป็น example.com ซึ่งถ้าหากไม่ระมัดระวัง พลาดกดเข้าไป ก็อาจกลายเป็นผู้เสียหายได้เลย โดยจุดประสงค์ของเว็บไซต์เหล่านี้คือ การหลอกล่อเอาข้อมูลของผู้ใช้งาน เช่น username password บัตรประชาชน บัตรเครดิต หรือข้อมูลส่วนตัวอื่น ๆ



ลักษณะสำคัญของ Web Phishing

1. URL ที่ผิดปกติ เว็บไซต์ Phishing มักจะใช้ URL ที่คล้ายกับเว็บไซต์จริง แต่มีการเปลี่ยนแปลงบางตัวอักษรหรือเพิ่มคำที่ทำให้แยกไม่ออก เช่น จาก example.co.th เป็น example.com หรือ ex4mple.co.th (ตัวเลขแทนตัวอักษร) ตรวจสอบ URL ทุกครั้งก่อนกรอกข้อมูล โดยเอาเมาส์ไปชี้ที่ลิงก์เพื่อดูว่า URL นั้นถูกต้องหรือไม่



2. การออกแบบที่ไม่สมบูรณ์หรือผิดปกติ เว็บไซต์ปลอมอาจมีการออกแบบที่ไม่สมบูรณ์ หรือแสดงผลผิดปกติ เช่น ภาพหรือฟอนต์ที่ดูแปลก หรือบางส่วนของเว็บไซต์ที่ไม่สามารถทำงานได้ตามปกติ

3. คำขอข้อมูลที่ละเอียดอ่อน เว็บไซต์ Phishing มักจะขอข้อมูลที่ไม่สมควรถาม เช่น รหัสผ่าน, หมายเลขบัตรเครดิต, หรือหมายเลขบัตรประชาชนผ่านฟอร์มออนไลน์ ซึ่งเว็บไซต์ที่แท้จริงไม่ควรขอข้อมูลเช่นนี้จากผู้ใช้

4. คำเตือนจากเบราว์เซอร์ เบราวเซอร์มักจะแจ้งเตือนเมื่อเว็บไซต์มีการเชื่อมต่อที่ไม่ปลอดภัย (เช่น ไม่มี HTTPS หรือใบรับรอง SSL) หรือเมื่อเว็บไซต์นั้นเป็นที่รู้จักว่ามีความเสี่ยง

5. การสร้างความเร่งด่วน เว็บไซต์ Phishing มักจะมีข้อความที่กระตุ้นให้เกิดความเร่งด่วน เช่น "กรุณายืนยันข้อมูลของคุณภายใน 24 ชั่วโมง" หรือ "บัญชีของคุณถูกล็อค กรุณาเข้าสู่ระบบเพื่อปลดล็อคทันที"

วิธีรับมือกับ Web Phishing

1. ตรวจสอบ URL ทุกครั้ง ให้ตรวจสอบที่อยู่ของเว็บไซต์ให้ถูกต้องเสมอ และอย่าคลิกลิงก์จากอีเมลหรือข้อความที่ไม่แน่ใจ ทุกครั้งก่อนกรอกข้อมูล โดยเอาเมาส์ไปชี้ที่ลิงก์เพื่อดูว่า URL นั้นถูกต้องหรือไม่

ในกรณีที่เป็นลิงก์ ประเภท URL Shortener เช่น bit.ly, goo.gl, หรือ tinyurl.com

1. ใช้บริการขยายลิงก์ (Expand URL) ใช้เว็บไซต์หรือเครื่องมือขยายลิงก์ เช่น [CheckShortURL](https://checkshorturl.unshorten.it) [Unshorten.it](https://unshorten.it) เพื่อดู URL ต้นทางก่อนคลิกลิงก์

2. ตรวจสอบผ่านโปรแกรมป้องกันไวรัส โปรแกรมป้องกันไวรัสหลาย สามารถตรวจสอบความปลอดภัยของลิงก์ได้

3. ดูข้อมูลลิงก์ผ่านบริการของ Shortener เพิ่ม "+" หลัง URL สำหรับบางบริการ เช่น bit.ly/example+ จะเปิดหน้ารายละเอียดของลิงก์

2. ใช้เครื่องมือป้องกันการ Phishing ใช้ซอฟต์แวร์ป้องกันมัลแวร์หรือเบราว์เซอร์ที่มีการป้องกัน Phishing เพื่อลดความเสี่ยงจากเว็บไซต์ที่เป็นอันตราย

3. ไม่กรอกข้อมูลส่วนตัวในเว็บไซต์ที่ไม่แน่ใจ อย่ากรอกข้อมูลส่วนตัว เช่น รหัสผ่าน หรือข้อมูลบัตรเครดิตในเว็บไซต์ที่ดูไม่น่าเชื่อถือ

4. ใช้การยืนยันตัวตนสองชั้น (2FA) เปิดใช้งานการยืนยันตัวตนสองชั้นในบัญชีที่รองรับ เพื่อเพิ่มความปลอดภัยหากบัญชีถูกโจมตีจากเว็บไซต์ Phishing

5. ระวังคำขอที่ผิดปกติ หากเว็บไซต์ขอข้อมูลที่ไม่สมเหตุสมผล เช่น รหัสผ่านหรือข้อมูลส่วนตัวที่ไม่ควรถามผ่านหน้าเว็บ ให้หยุดทำการและตรวจสอบเว็บไซต์นั้นทันที

6. ตรวจสอบชื่อโดเมน ชื่อโดเมนควรตรงกับเนื้อหาที่เกี่ยวข้องและไม่ดูแปลกปลอมหรือหลอกลวง

1.3 Smishing

Smishing หรือ SMS Phishing เป็นการหลอกลวงผ่านข้อความ SMS วิธีสังเกต ข้อความเหล่านี้จะถูกส่งมาจากเบอร์แปลกที่เป็นเบอร์ส่วนตัวของบุคคลทั่วไป อ้างว่าส่งมาจากองค์กรใหญ่ ๆ ซึ่งไม่สมเหตุสมผล บางที่เป็นข้อความที่ใช้ภาษาไม่เป็นทางการ พิมพ์ผิด หรือเป็นข้อความที่อ้างว่าเราได้รางวัล หรือทำให้งงวุ่น เช่น “พัสดุของคุณจัดส่งไม่สำเร็จ กรุณาลิกลิงก์เพื่อดำเนินการจัดส่งต่อ” คนที่ส่งของออนไลน์บ่อย ๆ ก็อาจจะหลงกลแล้วคลิกเข้าไป กรอกข้อมูลต่าง ๆ เพราะคิดว่าเป็น SMS จากขนส่งจริง หรืออาจจะเป็น SMS ที่หลอกล่อให้เราคลิกเข้าไปในเว็บไซต์ปลอมที่มีจิวาซีฟสร้างขึ้นก็ได้



ลักษณะสำคัญของ Smishing

1. ส่งข้อความจากเบอร์แปลก มักเป็นเบอร์โทรศัพท์ส่วนตัวที่ไม่เกี่ยวข้องกับองค์กรจริง
2. ใช้ข้อความที่ดูเร่งด่วน เช่น การแจ้งปัญหาที่ต้องแก้ไขทันที หรือการแจ้งว่าคุณได้รับรางวัล
3. ลิงก์ที่ดูไม่น่าเชื่อถือ ลิงก์ที่ส่งมามักเป็นโดเมนปลอมหรือย่อ URL ให้ดูเหมือนน่าเชื่อถือ เช่น bit.ly/abc123
4. ข้อความที่ไม่เป็นทางการหรือมีข้อผิดพลาด เช่น การพิมพ์ผิดหรือใช้ภาษาที่ดูไม่เป็นทางการ
5. ลักษณะข้อความมีเนื้อหาที่เกี่ยวข้องกับเหยื่อ เช่น การแจ้งปัญหาเกี่ยวกับพัสดุ, การยืนยันบัญชีธนาคาร, หรือการแจ้งเตือนจากหน่วยงานราชการ

ตัวอย่างข้อความ Smishing

1. การหลอกเกี่ยวกับพัสดุ

“พัสดุของคุณจัดส่งไม่สำเร็จ กรุณาคลิกลิงก์นี้เพื่อดำเนินการจัดส่งใหม่
[bit.ly/fakeparcel]”

2. การแจ้งเตือนจากธนาคารปลอม

“บัญชีของคุณถูกระงับชั่วคราว กรุณาเข้าสู่ระบบเพื่อยืนยันข้อมูล:
[fakebank.com/login]”

3. การแจ้งเตือนว่าได้รับรางวัล

“ยินดีด้วย! คุณได้รับ iPhone 15 ฟรี กรุณาคลิกที่นี่เพื่อรับของรางวัล [scamlink.com]”

วิธีป้องกันและรับมือกับ Smishing

1. ไม่คลิกลิงก์ในข้อความแปลก หากข้อความมาจากแหล่งที่ไม่รู้จัก ให้หลีกเลี่ยงการคลิกลิงก์ในข้อความ
2. ติดต่อองค์กรโดยตรง หากสงสัยว่าเป็นข้อความปลอม ให้ติดต่อองค์กรผ่านช่องทางที่เป็นทางการ เช่น เว็บไซต์หรือเบอร์โทรที่ได้รับการยืนยัน
3. ติดตั้งซอฟต์แวร์ป้องกันมัลแวร์ ใช้แอปพลิเคชันที่ช่วยตรวจจับลิงก์หรือข้อความอันตราย
4. อย่าให้ข้อมูลส่วนตัวผ่านข้อความ องค์กรที่น่าเชื่อถือจะไม่ขอข้อมูลส่วนตัว เช่น รหัสผ่าน หรือข้อมูลบัตรเครดิต ผ่าน SMS
5. รายงานข้อความหลอกลวง หากได้รับข้อความที่น่าสงสัย สามารถแจ้งเบอร์โทรศัพท์หรือข้อความนั้นต่อผู้ให้บริการโทรศัพท์มือถือหรือหน่วยงานที่เกี่ยวข้องเพื่อตรวจสอบ

1.4 Voice Phishing

Voice Phishing คือการหลอกลวงทางไซเบอร์ในรูปแบบเสียง โดยผู้โจมตีมักใช้การโทรศัพท์เพื่อหลอกล่อให้เหยื่อเปิดเผยข้อมูลส่วนตัวหรือโอนเงินให้ ซึ่งในปัจจุบันเป็นที่รู้จักในชื่อ **"แก๊งคอลเซ็นเตอร์"** ตัวอย่างวิธีการ Vishing เช่น อ้างว่าโทรมาจากองค์กรสำคัญ ปลอมเป็นคนที่รู้จัก อ้างว่าเหยื่อได้รับรางวัลหรือของสมนาคุณ เป็นต้น เมื่อเหยื่อตกหลุมพราง ผู้โจมตีมักขอข้อมูลสำคัญ เช่น หมายเลขบัตรประชาชน เลขบัญชีธนาคาร หรืออาจขอให้โอนเงินเข้าไปในบัญชีของพวกเขา

ลักษณะสำคัญของ Voice Phishing

1. แสดงตัวว่าเป็นบุคคลหรือองค์กรที่น่าเชื่อถือ เช่น ปลอมเป็นเจ้าหน้าที่ธนาคาร, หน่วยงานรัฐ, บริษัทที่เหยื่อเกี่ยวข้อง หรือ อ้างว่าโทรมาจากองค์กร เช่น สรรพากร, ตำรวจ, หรือศาล
2. สร้างสถานการณ์ที่เร่งด่วน แจ้งว่าเหยื่อมีความผิด, หนี้สิน, หรือข้อมูลสำคัญรั่วไหล ชูว่าจะมีผลกระทบร้ายแรงหากไม่ดำเนินการทันที เช่น การอายัดบัญชี
3. มีการโน้มน้าว ใช้ข้อมูลส่วนตัวของเหยื่อ (เช่น ชื่อ-สกุล หรือหมายเลขบัญชีบางส่วน) เพื่อสร้างความน่าเชื่อถือ อ้างว่ามีรางวัลหรือสิทธิพิเศษ เช่น การได้รับเงินคืนหรือของขวัญ
4. ขอข้อมูลสำคัญหรือการโอนเงิน ขอบหมายเลขบัตรเครดิต, หมายเลขบัตรประชาชน, หรือรหัส OTP
ขอให้โอนเงินเข้าบัญชีของผู้โจมตี

ตัวอย่างสถานการณ์ Voice Phishing

1. ปลอมเป็นเจ้าหน้าที่ธนาคาร

โทรศัพท์แจ้งว่า "บัญชีของคุณถูกเข้าถึงโดยไม่ได้รับอนุญาต กรุณาให้หมายเลขบัตรและรหัส OTP เพื่อยืนยันตัวตน มิฉะนั้นบัญชีของคุณจะถูกระงับ"

2. ปลอมเป็นตำรวจหรือศาล

แจ้งว่า "คุณมีหมายจับในข้อหาฟอกเงิน กรุณายืนยันตัวตนโดยให้ข้อมูลบัตรประชาชนและโอนเงินประกันตัวเพื่อยกเลิกหมายจับ"

3. อ้างว่าเป็นบริษัทขนส่ง

โทรแจ้งว่า "พัสดุของคุณถูกยึดที่ด่านศุลกากร กรุณาชำระค่าธรรมเนียมด่วน มิฉะนั้นพัสดุจะถูกทำลาย"

4. ปลอมเป็นคนรู้จัก

ผู้โจมตีอาจอ้างว่าเป็นเพื่อนหรือญาติ โทรมาขอความช่วยเหลือ เช่น "ฉันมีปัญหาเรื่องการเงินด่วน ขอให้คุณโอนเงินมาให้ก่อน"

วิธีรับมือกับ Voice Phishing

1. อย่าให้ข้อมูลส่วนตัวทางโทรศัพท์ องค์กรที่น่าเชื่อถือจะไม่ขอข้อมูลสำคัญ เช่น รหัส OTP หรือรหัสผ่านทางโทรศัพท์
2. ตั้งสติและไม่ตื่นตระหนก หากได้รับสายที่อ้างถึงสถานการณ์เร่งด่วน ให้หยุดและตรวจสอบข้อเท็จจริงก่อน
3. ติดต่อกลับองค์กรโดยตรง หากสงสัย ให้โทรไปยังหมายเลขที่ได้รับการยืนยันจากเว็บไซต์ทางการขององค์กร
4. บล็อกหมายเลขโทรศัพท์ต้องสงสัย ใช้ฟีเจอร์บล็อกหมายเลขหรือรายงานไปยังผู้ให้บริการโทรศัพท์
5. รายงานการหลอกลวง หากคุณตกเป็นเหยื่อ หรือได้รับสายหลอกลวง ให้แจ้งตำรวจหรือหน่วยงานที่เกี่ยวข้อง เช่น สำนักงานคุ้มครองผู้บริโภค